AI Use-Case Governance Readiness Report — SupportPilot

Synthetic example. *This report was generated from fictional data to illustrate VERITRAIL Agent output. It describes no real organization or system.*

Field	Value
Report ID	rpt_mvkluaio77ee4751
Assessment ID	asm_mvklu9wi0f25c6aa
AI system record	sys_mvklu9wg75f1615d
Generated (UTC)	2026-10-23T06:44:31+00:00
Prepared by	Asha Rao (synthetic AI CoE assessor) via VERITRAIL Agent
Question bank	VERITRAIL-UC-ASSESS v1.0.0
Control library	VERITRAIL Control Library v1.0.0
Evidence basis	Self-reported answers (User-asserted) unless evidence was reviewed by a named reviewer (Verified)

1. Executive summary

- **Preliminary risk tier: High** (Inferred; requires human confirmation — Confirmed by Dana Lee (synthetic CISO delegate) (2026-10-23)).
- **43 of 43** applicable questions answered across 9 modules.
- **39 gaps** identified: 6 Critical, 24 High, 5 Medium, 4 Low.
- **Evidence posture:** 3 finding(s) Verified by a named reviewer; 9 User-asserted; 25 Missing evidence; 6 Critical gap; 0 Inferred.
- **Priority actions (Critical, due within 30 days):**
  - GAP-001: Complete a tier-proportionate risk and impact assessment and obtain approval at the tier-appropriate gate before (further) production use. (GL-02, GL-03; owner: AI Risk Lead)
  - GAP-002: Deploy redaction/masking on prompts, responses, logs and external model calls; test it against representative records and retain the results. (IS-04; owner: Platform Engineering / Privacy Lead)
  - GAP-003: Restrict data access to the minimum records and fields required, using scoped service identities, and review access periodically. (IS-03, IS-11; owner: DPO / Privacy Lead)
  - GAP-004: Implement and test a kill switch and rollback runbook; record time-to-disable from the test. (IS-15; owner: Platform Engineering / SRE)
  - GAP-005: Run adversarial testing for direct and indirect prompt injection, jailbreaks and data leakage before release and after each material change. (IS-14; owner: Security Testing / Red Team)

This report indicates governance readiness and evidence gaps for one AI system. It is not a determination of conformity or legal compliance with any framework or law.

2. AI system profile

Field	Value	Evidence status
name	SupportPilot	User-asserted
purpose	A customer-support agent called SupportPilot that reads CRM data (customer profiles and order history), drafts replies to customers, updates support tickets and can issue goodwill refunds with supervisor approval.	User-asserted
domain_category	customer_service	User-asserted
decision_impact	advisory	User-asserted
affected_parties	customers	User-asserted

Field	Value	Evidence status
data_sensitivity	personal	User-asserted
autonomy	acts_with_approval	User-asserted
external_actions	Yes	User-asserted
genai	Yes	User-asserted
vendor_model	Yes	User-asserted
eu_exposure	Yes	User-asserted
tools	crm, ticketing, payments	User-asserted
environment	pilot	User-asserted

3. Risk tier and rationale

Tier: High (score 85) — evidence status: Inferred; requires human confirmation: yes.

Rationale: Preliminary tier High (score 85). Drivers: decision_impact=advisory (+5); affected_parties=customers (+10); data_sensitivity=personal (+15); autonomy=acts_with_approval (+15); tool_access=3 tool(s), 1 with write/act capability (+15); external_actions=True (+10); generative_ai=True (+5); third_party_model=True (+5); eu_exposure=True (+5). Inferred from user-provided intake; requires human confirmation.

Factor	Value	Points	Citation
decision_impact	advisory	5	VERITRAIL Control GL-02: Pre-deployment risk and impact assessment (Control Library v1.0.0)
affected_parties	customers	10	VERITRAIL Control EI-04: Intended purpose and context of use (Control Library v1.0.0)
data_sensitivity	personal	15	VERITRAIL Control IS-03: Privacy assessment and data minimisation (Control Library v1.0.0)
autonomy	acts_with_approval	15	VERITRAIL Control IS-09: Human oversight design (Control Library v1.0.0)
tool_access	3 tool(s), 1 with write/act capability	15	VERITRAIL Control IS-11: Least-privilege tool access (Control Library v1.0.0)
external_actions	Yes	10	VERITRAIL Control IS-13: Human approval for high-impact actions (Control Library v1.0.0)
domain_category	customer_service	0	VERITRAIL Control EI-02: AI risk classification and tiering (Control Library v1.0.0)
generative_ai	Yes	5	VERITRAIL Control IS-14: Prompt-injection and data-leakage testing (Control Library v1.0.0)
third_party_model	Yes	5	VERITRAIL Control GL-11: Vendor AI due diligence and contract controls (Control Library v1.0.0)
eu_exposure	Yes	5	VERITRAIL Control AO-07: Regulatory and contractual obligations register (Control Library v1.0.0)

- Approval authority for this tier: AI Governance Forum
- Review cadence: every 6 months
- Assessment modules applied: Core governance & lifecycle, Data & privacy, Security & resilience, Generative AI & LLM controls, Agentic AI & tool use, Fairness, safety & transparency, Human oversight & operations, Vendor & third-party AI, Monitoring, incidents & evidence
- Method: VERITRAIL risk-tier rules v1.0 (thresholds: High >= 60 or any high-risk trigger; Medium >= 30)

4. Domain heat map

Domain	Qs	Implementation (self-reported)	Verified	Crit	High	Med	Low	Rating
Strategy & Accountability	2	75.0%	0	0	1	1	0	High exposure

Domain	Qs	Implementation (self-reported)	Verified	Crit	High	Med	Low	Rating
AI Inventory & Visibility	4	87.5%	1	0	1	1	1	High exposure
Risk Management & Lifecycle	8	37.5%	0	1	5	0	2	Critical exposure
Data & Privacy	5	20.0%	0	2	3	0	0	Critical exposure
Security & Resilience	9	38.9%	0	3	4	1	1	Critical exposure
Fairness, Safety & Transparency	5	62.5%	1	0	3	0	0	High exposure
Human Oversight & Operations	6	58.3%	1	0	4	1	0	High exposure
Assurance, Evidence & Improvement	4	25.0%	0	0	3	1	0	High exposure

Implementation indicator = implemented (1.0) and partial (0.5) answers as a share of applicable questions; it reflects self-reported answers, not verified evidence.

5. Gap register

Gap · severity · due	Evidence status	Question	Controls	Owner role	Recommended action
GAP-001 · Critical · due 2026-11-20	Critical gap	UC-CORE-Q4: Was a pre-deployment risk and impact assessment completed and approved at the gate appropriate to the risk tier?	GL-02, GL-03	AI Risk Lead	Complete a tier-proportionate risk and impact assessment and obtain approval at the tier-appropriate gate before (further) production use.
GAP-002 · Critical · due 2026-11-20	Critical gap	UC-DATA-Q3: Are personal and sensitive fields redacted or masked before they reach prompts, logs and external model calls?	IS-04	Platform Engineering / Privacy Lead	Deploy redaction/masking on prompts, responses, logs and external model calls; test it against representative records and retain the results.
GAP-003 · Critical · due 2026-11-20	Critical gap	UC-DATA-Q4: Is the system's data access limited to the minimum records and fields it needs (e.g. field-level scoping of CRM access)?	IS-03, IS-11	DPO / Privacy Lead	Restrict data access to the minimum records and fields required, using scoped service identities, and review access periodically.
GAP-004 · Critical · due 2026-11-20	Critical gap	UC-SEC-Q3: Is there a tested kill switch and rollback procedure that can disable the system, model, agent or individual tools quickly?	IS-15	Platform Engineering / SRE	Implement and test a kill switch and rollback runbook; record time-to-disable from the test.
GAP-005 · Critical · due 2026-11-20	Critical gap	UC-GEN-Q1: Has the system been tested for prompt injection (direct and indirect), jailbreaks and data leakage before release and after material changes?	IS-14	Security Testing / Red Team	Run adversarial testing for direct and indirect prompt injection, jailbreaks and data leakage before release and after each material change.
GAP-006 · Critical · due 2026-11-20	Critical gap	UC-AGT-Q2: Does each tool use least-privilege credentials scoped to the required actions only (no shared or admin credentials)?	IS-11	Platform Engineering / IAM	Replace shared/admin credentials with per-tool, least-privilege scoped identities and review access periodically.
GAP-007 · High · due 2026-12-20	Missing evidence	UC-CORE-Q3: Has the use case passed intake triage and received a risk tier that was confirmed by an accountable approver?	GL-01, EI-02, EI-12	AI Risk Lead	Run the use case through intake triage and record a human-confirmed risk tier with rationale in the intake register.
GAP-008 · High · due 2026-12-20	Missing evidence	UC-DATA-Q2: Has a privacy / data-protection impact assessment been completed covering lawful basis, minimisation, retention and cross-border transfers?	IS-03	DPO / Privacy Lead	Complete a privacy impact assessment (DPIA where required) covering lawful basis, minimisation, retention and transfers, signed off by the DPO/privacy lead.

Gap · severity · due	Evidence status	Question	Controls	Owner role	Recommended action
GAP-009 · High · due 2026-12-20	Missing evidence	UC-DATA-Q5: Are retention periods defined and enforced for prompts, outputs, conversation transcripts and logs?	IS-03, SE-02	DPO / Privacy Lead	Define and enforce retention periods for prompts, outputs, transcripts and logs consistent with the privacy assessment.
GAP-010 · High · due 2026-12-20	Missing evidence	UC-AGT-Q1: Is the agent registered with every tool it can call, the scopes of each tool and the permitted actions?	EI-07	Platform Engineering Lead	Register the agent and a tool/permission manifest listing each tool, scope and permitted action.
GAP-011 · High · due 2026-12-20	Missing evidence	UC-AGT-Q4: Are all agent tool calls logged in a tamper-evident log with trace IDs, redacted inputs and outcomes?	SE-08	Platform Engineering / Security Operations	Log every tool call with trace ID, redacted inputs, decision and outcome to tamper-evident storage with defined retention.
GAP-012 · High · due 2026-12-20	Missing evidence	UC-HUM-Q1: Is the human oversight design documented — who reviews which outputs or actions, when, and with authority to override or stop the system?	IS-09	Business Owner	Document the oversight design (reviewer roles, review points, override and stop authority) and keep records of oversight in operation.
GAP-013 · High · due 2026-12-20	Missing evidence	UC-CORE-Q5: Have the legal, regulatory and contractual obligations that apply to this system (by jurisdiction) been identified and reviewed?	AO-07	Legal / Compliance	Add the system to the obligations register and obtain a legal review of applicable obligations by jurisdiction.
GAP-014 · High · due 2026-12-20	Missing evidence	UC-CORE-Q7: Are changes to the model, prompts, data, tools or vendor subject to change control with defined reassessment triggers?	GL-04, EI-05	Engineering / Change Advisory Board	Add AI-specific change triggers (model, prompt, data, tool, vendor) to change management and require reassessment when they fire.
GAP-015 · High · due 2026-12-20	Missing evidence	UC-DATA-Q1: Are the data sources, classifications and data flows used for training, grounding (RAG) and prompts documented for this system?	EI-06, IS-02	Data Owner / CDO office	Document every data source, its classification and the data flows into prompts, retrieval indexes, logs and external services.
GAP-016 · High · due 2026-12-20	Missing evidence	UC-SEC-Q1: Has an AI-specific threat model been completed for this system (e.g. prompt injection, data poisoning, model abuse, tool misuse)?	IS-01	CISO / Security Architecture	Produce an AI-specific threat model covering injection, poisoning, abuse and tool misuse, and track mitigations to closure.
GAP-017 · High · due 2026-12-20	Missing evidence	UC-SEC-Q4: Were pre-release validation and robustness tests run against documented acceptance criteria, with results retained?	GL-05, IS-07	QA / ML Engineering	Define acceptance criteria, run pre-release validation and robustness tests, and retain signed-off results.
GAP-018 · High · due 2026-12-20	Missing evidence	UC-GEN-Q2: Are runtime guardrails (input/output filtering, PII detection, topic restrictions) enforced through a versioned runtime policy?	IS-12	Platform Engineering / Security	Enforce a versioned runtime policy for input/output filtering, PII detection and topic restrictions, starting in monitor mode then enforce.
GAP-019 · High · due 2026-12-20	Missing evidence	UC-GEN-Q5: Are groundedness / hallucination rates and output quality evaluated against defined thresholds?	IS-07, IS-06	ML Engineering	Define groundedness and quality thresholds and evaluate against a representative test set before release and periodically.
GAP-020 · High · due 2026-12-20	Missing evidence	UC-AGT-Q5: Are per-action limits (value caps, rate limits, loop/step limits) enforced at runtime for agent actions?	IS-12, IS-16	Platform Engineering / Security	Enforce value caps, rate limits and step limits for agent actions in the runtime policy with alerts on breach.
GAP-021 · High · due 2026-12-20	Missing evidence	UC-FAIR-Q2: Has a safety and harm evaluation been completed (harmful, misleading or inappropriate outputs, including for vulnerable users)?	IS-06	Responsible AI Lead	Complete a harm analysis and safety evaluation, including vulnerable-user scenarios, and obtain residual-risk sign-off.

Gap · severity · due	Evidence status	Question	Controls	Owner role	Recommended action
GAP-022 · High · due 2026-12-20	Missing evidence	UC-FAIR-Q4: Can affected individuals obtain an explanation, reach a human, and contest or appeal outcomes?	IS-08, AO-11	Product Owner / Legal	Provide a route to a human, explanations proportionate to impact, and a contest/appeal channel whose outcomes are logged.
GAP-023 · High · due 2026-12-20	Missing evidence	UC-HUM-Q2: Are operators and reviewers trained on the system's limitations, automation bias and escalation paths?	AO-05	HR / Learning lead with AI Governance Lead	Deliver role-based training for operators and reviewers covering limitations, automation bias and escalation, and track completion.
GAP-024 · High · due 2026-12-20	Missing evidence	UC-HUM-Q4: Were go-live deployment conditions defined, verified and signed off before production use?	GL-07	Product Owner	Define go-live conditions (controls, monitoring, oversight) and verify them with a signed checklist before production use.
GAP-025 · High · due 2026-12-20	Missing evidence	UC-VEN-Q2: Do contract terms cover data-use restrictions, no training on your data, retention, breach notification and audit rights?	GL-11, AO-09	Procurement / Vendor Risk	Negotiate or confirm AI contract clauses for data use, training restrictions, retention, breach notification and audit rights.
GAP-026 · High · due 2026-12-20	Missing evidence	UC-VEN-Q4: Are vendor model version changes and deprecations monitored and routed through change control?	GL-04, EI-05	Engineering / Change Advisory Board	Monitor vendor model/version announcements and route changes through change control with reassessment triggers.
GAP-027 · High · due 2026-12-20	Missing evidence	UC-MON-Q1: Is production performance, drift and misuse monitored against thresholds with alerts and review?	GL-08, SE-12	ML Ops / Product Owner	Instrument performance, drift and misuse monitoring with thresholds, alerts and a recurring review.
GAP-028 · High · due 2026-12-20	Missing evidence	UC-MON-Q2: Is this system covered by an AI incident management procedure, including internal and external reporting timelines?	SE-04	CISO / Operational Risk	Bring the system under the AI incident procedure with defined severity levels and reporting timelines; Legal to confirm external reporting duties.
GAP-029 · High · due 2026-12-20	Missing evidence	UC-MON-Q3: Is evidence for this system's controls retained in an evidence repository, and can an audit-ready evidence pack be produced on request?	SE-02, SE-05	AI Governance Lead	Store control evidence for this system in the evidence repository with retention rules and assemble an audit-ready evidence pack.
GAP-030 · High · due 2026-12-20	Missing evidence	UC-MON-Q5: Is technical documentation (system/model card, architecture, data, testing, limitations) maintained for this system?	GL-06	Product / ML Engineering	Produce and maintain technical documentation including a system/model card, architecture, data, testing and known limitations.
GAP-031 · Medium · due 2027-01-19	User-asserted	UC-CORE-Q6: Has the use case been screened against the organization's prohibited and restricted AI use policy?	AO-10	Legal / AI Governance Lead	Screen the use case against the prohibited/restricted AI use list and record the outcome; escalate any match for legal review.
GAP-032 · Medium · due 2027-01-19	User-asserted	UC-HUM-Q3: Is there a defined escalation path for concerns and AI incidents involving this system?	AO-06, SE-04	AI Governance Lead	Define and communicate an escalation path and incident procedure for this system, with named contacts and timeframes.
GAP-033 · Medium · due 2027-01-19	User-asserted	UC-VEN-Q3: Is the vendor AI product recorded in the third-party AI inventory with an accountable owner?	EI-08, AO-09	Procurement / Vendor Risk	Record the vendor AI product in the third-party AI inventory with an accountable owner and contract/DPA references.
GAP-034 · Medium · due 2027-01-19	User-asserted	UC-GEN-Q3: Are rate, token and spend limits configured and alerting when breached?	IS-16	Platform Engineering / FinOps	Configure rate, token and budget limits per user and per system with breach alerts.
GAP-035 · Medium · due 2027-01-19	Missing evidence	UC-MON-Q4: Is a periodic review / recertification of this system scheduled at the cadence required by its risk tier?	GL-12, EI-11	AI Risk Lead	Schedule periodic review and recertification at the cadence set for the system's risk tier.

Gap · severity · due	Evidence status	Question	Controls	Owner role	Recommended action
GAP-036 · Low · due 2027-04-19	User-asserted	UC-CORE-Q2: Are the intended purpose, context of use, users, affected parties and out-of-scope uses documented?	EI-04	Product Owner	Document intended purpose, context of use, users, affected parties and explicitly out-of-scope or foreseeable misuse.
GAP-037 · Low · due 2027-04-19	User-asserted	UC-SEC-Q2: Do models, prompts, plugins and third-party components come from an approved, integrity-checked supply chain?	IS-10, EI-05	Security Architecture	Restrict models and components to an approved list with integrity checks and dependency scanning.
GAP-038 · Low · due 2027-04-19	User-asserted	UC-GEN-Q4: Are system prompts and prompt templates version-controlled in a registry alongside the model version?	EI-05, IS-10	ML / Platform Engineering Lead	Version system prompts and templates in a registry linked to model versions and change tickets.
GAP-039 · Low · due 2027-04-19	User-asserted	UC-VEN-Q1: Was vendor AI due diligence completed for the model/service provider (security, data use, model training on your data, subprocessors)?	GL-11	Procurement / Vendor Risk	Complete AI-specific vendor due diligence covering security, data use, training on customer data and subprocessors.

Due dates apply the VERITRAIL severity SLAs (Critical 30, High 60, Medium 90, Low 180 days) from 2026-10-21.

6. Control recommendations

Control	Title	Priority	Highest gap severity	Owner role	Framework mappings (indicative)
GL-02	Pre-deployment risk and impact assessment	critical	Critical	AI Risk Lead	NIST AI RMF: MAP 1.1, MAP 3.1, MAP 5.1, MEASURE 1.1; ISO/IEC 42001: 6.1.4, 8.4, A.5.2, A.5.3, A.5.4; EU AI Act: Art. 9, Art. 27
GL-03	Risk-tiered approval gates	critical	Critical	AI Governance Forum	NIST AI RMF: MANAGE 1.1, GOVERN 1.4; ISO/IEC 42001: 8.1, A.6.2.5; EU AI Act: Art. 9, Art. 43
IS-03	Privacy assessment and data minimisation	critical	Critical	DPO / Privacy Lead	NIST AI RMF: MEASURE 2.10, MAP 1.1; ISO/IEC 42001: A.7.4, A.5.4; EU AI Act: Art. 10
IS-04	Sensitive data redaction and masking	critical	Critical	Platform Engineering / Privacy Lead	NIST AI RMF: MEASURE 2.10; ISO/IEC 42001: A.7.4, A.6.2.6; EU AI Act: Art. 10
IS-11	Least-privilege tool access	critical	Critical	Platform Engineering / IAM	NIST AI RMF: MEASURE 2.7, MANAGE 2.2; ISO/IEC 42001: A.6.2.6, A.4.4; EU AI Act: Art. 15, Art. 14
IS-14	Prompt-injection and data-leakage testing	critical	Critical	Security Testing / Red Team	NIST AI RMF: MEASURE 2.7; ISO/IEC 42001: A.6.2.4; EU AI Act: Art. 15
IS-15	Kill switch and rollback	critical	Critical	Platform Engineering / SRE	NIST AI RMF: MANAGE 2.4; ISO/IEC 42001: A.6.2.6; EU AI Act: Art. 14
EI-02	AI risk classification and tiering	critical	High	AI Risk Lead	NIST AI RMF: MAP 1.1, MAP 1.5, GOVERN 1.3; ISO/IEC 42001: 6.1.2, A.5.2; EU AI Act: Art. 6
EI-07	Agent and tool registry	critical	High	Platform Engineering Lead	NIST AI RMF: GOVERN 1.6, MAP 4.1; ISO/IEC 42001: A.4.4, A.6.2.3; EU AI Act: Art. 11
IS-09	Human oversight design	critical	High	Business Owner	NIST AI RMF: GOVERN 3.2, MAP 3.5; ISO/IEC 42001: A.9.2, A.6.2.6; EU AI Act: Art. 14, Art. 26
SE-08	Immutable action logging	critical	High	Platform Engineering / Security Operations	NIST AI RMF: MEASURE 2.8, MANAGE 4.1; ISO/IEC 42001: A.6.2.8; EU AI Act: Art. 12, Art. 19, Art. 26
AO-05	AI literacy and role-based training	high	High	HR / Learning lead with AI Governance Lead	NIST AI RMF: GOVERN 2.2; ISO/IEC 42001: 7.2, 7.3, A.4.6; EU AI Act: Art. 4

Control	Title	Priority	Highest gap severity	Owner role	Framework mappings (indicative)
AO-07	Regulatory and contractual obligations register	high	High	Legal / Compliance	NIST AI RMF: GOVERN 1.1; ISO/IEC 42001: 4.1, 4.2, 6.1; EU AI Act: Art. 6, Art. 26
EI-05	Model, prompt and component registry	high	High	ML / Platform Engineering Lead	NIST AI RMF: MAP 4.1, GOVERN 1.6; ISO/IEC 42001: A.4.4, A.6.2.3; EU AI Act: Art. 11
EI-06	Data source and lineage registry	high	High	Data Owner / CDO office	NIST AI RMF: MAP 2.3, MEASURE 2.10; ISO/IEC 42001: A.4.3, A.7.5; EU AI Act: Art. 10
EI-12	Use-case intake register	high	High	AI CoE	NIST AI RMF: MAP 1.1; ISO/IEC 42001: A.5.2, A.6.1.3; EU AI Act: Art. 6
GL-01	Intake triage workflow	high	High	AI CoE	NIST AI RMF: MAP 1.1, MAP 1.6; ISO/IEC 42001: 8.1, A.6.1.3; EU AI Act: Art. 9
GL-04	Change management and reassessment triggers	high	High	Engineering / Change Advisory Board	NIST AI RMF: GOVERN 1.4, MANAGE 2.4; ISO/IEC 42001: 6.3, A.6.2.6; EU AI Act: Art. 43
GL-05	Pre-release validation and testing	high	High	QA / ML Engineering	NIST AI RMF: MEASURE 2.1, MEASURE 2.3, MEASURE 2.5; ISO/IEC 42001: A.6.2.4; EU AI Act: Art. 9, Art. 15
GL-06	Technical documentation	high	High	Product / ML Engineering	NIST AI RMF: MAP 2.2, MEASURE 2.9; ISO/IEC 42001: 7.5, A.6.2.7, A.6.2.3; EU AI Act: Art. 11
GL-07	Deployment conditions and go-live readiness	high	High	Product Owner	NIST AI RMF: MANAGE 1.2, MANAGE 2.1; ISO/IEC 42001: A.6.2.5; EU AI Act: Art. 26
GL-08	Post-deployment monitoring	high	High	ML Ops / Product Owner	NIST AI RMF: MEASURE 3.1, MANAGE 4.1; ISO/IEC 42001: 9.1, A.6.2.6; EU AI Act: Art. 26, Art. 72
GL-11	Vendor AI due diligence and contract controls	high	High	Procurement / Vendor Risk	NIST AI RMF: GOVERN 6.1, MAP 4.1; ISO/IEC 42001: A.10.3, A.10.4; EU AI Act: Art. 25
IS-01	AI threat modelling	high	High	CISO / Security Architecture	NIST AI RMF: MAP 5.1, MEASURE 2.7; ISO/IEC 42001: 6.1.2, A.6.1.3; EU AI Act: Art. 15
IS-02	Data governance and quality	high	High	Data Owner	NIST AI RMF: MAP 2.3, MEASURE 2.1; ISO/IEC 42001: A.7.2, A.7.3, A.7.4, A.7.6; EU AI Act: Art. 10
IS-06	Safety and harm evaluation	high	High	Responsible AI Lead	NIST AI RMF: MEASURE 2.6, MAP 5.1; ISO/IEC 42001: A.5.4, A.5.5; EU AI Act: Art. 9
IS-07	Accuracy and robustness testing	high	High	ML Engineering	NIST AI RMF: MEASURE 2.5; ISO/IEC 42001: A.6.2.4; EU AI Act: Art. 15
IS-08	Transparency and AI disclosures	high	High	Product Owner / Legal	NIST AI RMF: MEASURE 2.8, MEASURE 2.9; ISO/IEC 42001: A.8.2, A.8.5; EU AI Act: Art. 13, Art. 50
IS-12	Runtime guardrails and policy enforcement	high	High	Platform Engineering / Security	NIST AI RMF: MANAGE 2.2, MANAGE 2.4, MEASURE 2.7; ISO/IEC 42001: A.6.2.6; EU AI Act: Art. 15, Art. 14
SE-02	Evidence repository and retention	high	High	AI Governance Lead	NIST AI RMF: GOVERN 1.4; ISO/IEC 42001: 7.5; EU AI Act: Art. 18, Art. 19
SE-04	AI incident management and reporting	high	High	CISO / Operational Risk	NIST AI RMF: MANAGE 4.3, MANAGE 2.3; ISO/IEC 42001: 10.2, A.8.4; EU AI Act: Art. 73, Art. 26
SE-05	Audit-ready evidence packs	high	High	AI Governance Lead	NIST AI RMF: GOVERN 1.4, MEASURE 2.9; ISO/IEC 42001: 7.5, 9.2; EU AI Act: Art. 11, Art. 18

Control	Title	Priority	Highest gap severity	Owner role	Framework mappings (indicative)
SE-12	Model performance and drift monitoring	high	High	ML Ops	NIST AI RMF: MEASURE 2.4, MEASURE 3.1; ISO/IEC 42001: A.6.2.6; EU AI Act: Art. 72, Art. 15
AO-09	Third-party AI accountability	medium	High	Procurement / Vendor Risk	NIST AI RMF: GOVERN 6.1, GOVERN 6.2; ISO/IEC 42001: A.10.2, A.10.3; EU AI Act: Art. 25, Art. 26
AO-11	Stakeholder engagement and feedback	medium	High	Product Owner	NIST AI RMF: GOVERN 5.1, GOVERN 5.2; ISO/IEC 42001: 4.2, A.8.3, A.8.5; EU AI Act: Art. 27
IS-16	Rate, budget and resource limits	medium	High	Platform Engineering / FinOps	NIST AI RMF: MANAGE 2.2; ISO/IEC 42001: A.4.5, A.6.2.6; EU AI Act: Art. 15
AO-10	Prohibited and restricted AI use policy	critical	Medium	Legal / AI Governance Lead	NIST AI RMF: GOVERN 1.1, MAP 1.1; ISO/IEC 42001: A.9.4, A.2.2; EU AI Act: Art. 5
AO-06	Escalation paths and decision rights	high	Medium	AI Governance Lead	NIST AI RMF: GOVERN 2.1, GOVERN 4.3; ISO/IEC 42001: 5.3, A.3.3; EU AI Act: Art. 26
EI-08	Third-party and vendor AI inventory	high	Medium	Procurement / Vendor Risk	NIST AI RMF: GOVERN 6.1; ISO/IEC 42001: A.10.3; EU AI Act: Art. 25
EI-11	Inventory attestation and recertification	medium	Medium	AI Governance Lead	NIST AI RMF: GOVERN 1.5; ISO/IEC 42001: 9.1
GL-12	Periodic review and recertification	medium	Medium	AI Risk Lead	NIST AI RMF: GOVERN 1.5; ISO/IEC 42001: 9.3; EU AI Act: Art. 9
EI-04	Intended purpose and context of use	high	Low	Product Owner	NIST AI RMF: MAP 1.1, MAP 1.2, MAP 3.4; ISO/IEC 42001: A.6.2.2, A.9.4; EU AI Act: Art. 11, Art. 13
IS-10	Secure model and prompt supply chain	high	Low	Security Architecture	NIST AI RMF: GOVERN 6.1, MEASURE 2.7; ISO/IEC 42001: A.10.3, A.6.2.3; EU AI Act: Art. 15

7. Remediation roadmap (30/60/90 days)

First 30 days — contain Critical exposure

- GAP-001 (Critical): Complete a tier-proportionate risk and impact assessment and obtain approval at the tier-appropriate gate before (further) production use. — GL-02, GL-03; owner: AI Risk Lead; due 2026-11-20
- GAP-002 (Critical): Deploy redaction/masking on prompts, responses, logs and external model calls; test it against representative records and retain the results. — IS-04; owner: Platform Engineering / Privacy Lead; due 2026-11-20
- GAP-003 (Critical): Restrict data access to the minimum records and fields required, using scoped service identities, and review access periodically. — IS-03, IS-11; owner: DPO / Privacy Lead; due 2026-11-20
- GAP-004 (Critical): Implement and test a kill switch and rollback runbook; record time-to-disable from the test. — IS-15; owner: Platform Engineering / SRE; due 2026-11-20
- GAP-005 (Critical): Run adversarial testing for direct and indirect prompt injection, jailbreaks and data leakage before release and after each material change. — IS-14; owner: Security Testing / Red Team; due 2026-11-20
- GAP-006 (Critical): Replace shared/admin credentials with per-tool, least-privilege scoped identities and review access periodically. — IS-11; owner: Platform Engineering / IAM; due 2026-11-20

Days 31–60 — close High gaps

- GAP-007 (High): Run the use case through intake triage and record a human-confirmed risk tier with rationale in the intake register. — GL-01, EI-02, EI-12; owner: AI Risk Lead; due 2026-12-20

- GAP-008 (High): Complete a privacy impact assessment (DPIA where required) covering lawful basis, minimisation, retention and transfers, signed off by the DPO/privacy lead. — IS-03; owner: DPO / Privacy Lead; due 2026-12-20
- GAP-009 (High): Define and enforce retention periods for prompts, outputs, transcripts and logs consistent with the privacy assessment. — IS-03, SE-02; owner: DPO / Privacy Lead; due 2026-12-20
- GAP-010 (High): Register the agent and a tool/permission manifest listing each tool, scope and permitted action. — EI-07; owner: Platform Engineering Lead; due 2026-12-20
- GAP-011 (High): Log every tool call with trace ID, redacted inputs, decision and outcome to tamper-evident storage with defined retention. — SE-08; owner: Platform Engineering / Security Operations; due 2026-12-20
- GAP-012 (High): Document the oversight design (reviewer roles, review points, override and stop authority) and keep records of oversight in operation. — IS-09; owner: Business Owner; due 2026-12-20
- GAP-013 (High): Add the system to the obligations register and obtain a legal review of applicable obligations by jurisdiction. — AO-07; owner: Legal / Compliance; due 2026-12-20
- GAP-014 (High): Add AI-specific change triggers (model, prompt, data, tool, vendor) to change management and require reassessment when they fire. — GL-04, EI-05; owner: Engineering / Change Advisory Board; due 2026-12-20
- GAP-015 (High): Document every data source, its classification and the data flows into prompts, retrieval indexes, logs and external services. — EI-06, IS-02; owner: Data Owner / CDO office; due 2026-12-20
- GAP-016 (High): Produce an AI-specific threat model covering injection, poisoning, abuse and tool misuse, and track mitigations to closure. — IS-01; owner: CISO / Security Architecture; due 2026-12-20
- GAP-017 (High): Define acceptance criteria, run pre-release validation and robustness tests, and retain signed-off results. — GL-05, IS-07; owner: QA / ML Engineering; due 2026-12-20
- GAP-018 (High): Enforce a versioned runtime policy for input/output filtering, PII detection and topic restrictions, starting in monitor mode then enforce. — IS-12; owner: Platform Engineering / Security; due 2026-12-20
- GAP-019 (High): Define groundedness and quality thresholds and evaluate against a representative test set before release and periodically. — IS-07, IS-06; owner: ML Engineering; due 2026-12-20
- GAP-020 (High): Enforce value caps, rate limits and step limits for agent actions in the runtime policy with alerts on breach. — IS-12, IS-16; owner: Platform Engineering / Security; due 2026-12-20
- GAP-021 (High): Complete a harm analysis and safety evaluation, including vulnerable-user scenarios, and obtain residual-risk sign-off. — IS-06; owner: Responsible AI Lead; due 2026-12-20
- GAP-022 (High): Provide a route to a human, explanations proportionate to impact, and a contest/appeal channel whose outcomes are logged. — IS-08, AO-11; owner: Product Owner / Legal; due 2026-12-20
- GAP-023 (High): Deliver role-based training for operators and reviewers covering limitations, automation bias and escalation, and track completion. — AO-05; owner: HR / Learning lead with AI Governance Lead; due 2026-12-20
- GAP-024 (High): Define go-live conditions (controls, monitoring, oversight) and verify them with a signed checklist before production use. — GL-07; owner: Product Owner; due 2026-12-20
- GAP-025 (High): Negotiate or confirm AI contract clauses for data use, training restrictions, retention, breach notification and audit rights. — GL-11, AO-09; owner: Procurement / Vendor Risk; due 2026-12-20
- GAP-026 (High): Monitor vendor model/version announcements and route changes through change control with reassessment triggers. — GL-04, EI-05; owner: Engineering / Change Advisory Board; due 2026-12-20
- GAP-027 (High): Instrument performance, drift and misuse monitoring with thresholds, alerts and a recurring review. — GL-08, SE-12; owner: ML Ops / Product Owner; due 2026-12-20
- GAP-028 (High): Bring the system under the AI incident procedure with defined severity levels and reporting timelines; Legal to confirm external reporting duties. — SE-04; owner: CISO / Operational Risk; due 2026-12-20
- GAP-029 (High): Store control evidence for this system in the evidence repository with retention rules and assemble an audit-ready evidence pack. — SE-02, SE-05; owner: AI Governance Lead; due 2026-12-20

- GAP-030 (High): Produce and maintain technical documentation including a system/model card, architecture, data, testing and known limitations. — GL-06; owner: Product / ML Engineering; due 2026-12-20

Days 61–90 — standardise and evidence

- GAP-031 (Medium): Screen the use case against the prohibited/restricted AI use list and record the outcome; escalate any match for legal review. — AO-10; owner: Legal / AI Governance Lead; due 2027-01-19
- GAP-032 (Medium): Define and communicate an escalation path and incident procedure for this system, with named contacts and timeframes. — AO-06, SE-04; owner: AI Governance Lead; due 2027-01-19
- GAP-033 (Medium): Record the vendor AI product in the third-party AI inventory with an accountable owner and contract/DPA references. — EI-08, AO-09; owner: Procurement / Vendor Risk; due 2027-01-19
- GAP-034 (Medium): Configure rate, token and budget limits per user and per system with breach alerts. — IS-16; owner: Platform Engineering / FinOps; due 2027-01-19
- GAP-035 (Medium): Schedule periodic review and recertification at the cadence set for the system's risk tier. — GL-12, EI-11; owner: AI Risk Lead; due 2027-01-19

Beyond 90 days — evidence hygiene backlog

- GAP-036 (Low): Document intended purpose, context of use, users, affected parties and explicitly out-of-scope or foreseeable misuse. — EI-04; owner: Product Owner; due 2027-04-19
- GAP-037 (Low): Restrict models and components to an approved list with integrity checks and dependency scanning. — IS-10, EI-05; owner: Security Architecture; due 2027-04-19
- GAP-038 (Low): Version system prompts and templates in a registry linked to model versions and change tickets. — EI-05, IS-10; owner: ML / Platform Engineering Lead; due 2027-04-19
- GAP-039 (Low): Complete AI-specific vendor due diligence covering security, data use, training on customer data and subprocessors. — GL-11; owner: Procurement / Vendor Risk; due 2027-04-19

8. Audit-ready evidence checklist

Done	Question	Controls	Evidence expected	Evidence provided	Status
[x]	UC-CORE-Q1	EI-03, EI-01	Inventory record with owner fields populated; Owner acceptance record	EV-SP-001	Verified
[ ]	UC-CORE-Q2	EI-04	System profile with intended purpose; Users and affected parties; Foreseeable misuse analysis	EV-SP-002	User-asserted
[ ]	UC-CORE-Q3	GL-01, EI-02, EI-12	Intake register entry; Triage decision with rationale; Tiering approval record	—	Missing evidence
[ ]	UC-CORE-Q4	GL-02, GL-03	Completed risk/impact assessment; Reviewer sign-off; Approval record with conditions; Residual-risk statement	—	Critical gap
[ ]	UC-CORE-Q5	AO-07	Obligations register entry for this system; Legal review record	—	Missing evidence
[ ]	UC-CORE-Q6	AO-10	Intake screening record against prohibited/restricted use list	—	User-asserted
[ ]	UC-CORE-Q7	GL-04, EI-05	Change policy with AI-specific triggers; Change tickets referencing reassessment; Model/prompt version history	—	Missing evidence
[ ]	UC-DATA-Q1	EI-06, IS-02	Data source register entries; Data-flow diagram; Data classification per source	—	Missing evidence
[ ]	UC-DATA-Q2	IS-03	Privacy/data-protection impact assessment; Retention schedule; Transfer assessment	DOC-DPIA-07	Missing evidence
[ ]	UC-DATA-Q3	IS-04	Redaction configuration; Redaction test results; Log samples showing masking	—	Critical gap
[ ]	UC-DATA-Q4	IS-03, IS-11	Access-scope configuration; Field-level access matrix; Access review record	—	Critical gap

Done	Question	Controls	Evidence expected	Evidence provided	Status
[ ]	UC-DATA-Q5	IS-03, SE-02	Retention schedule covering AI artefacts; Deletion job configuration or records	—	Missing evidence
[ ]	UC-SEC-Q1	IS-01	Threat model document; Mitigation tracking	—	Missing evidence
[ ]	UC-SEC-Q2	IS-10, EI-05	Approved model/provider list; Integrity checks; Dependency scanning results	EV-SP-010	User-asserted
[ ]	UC-SEC-Q3	IS-15	Kill-switch procedure; Kill-switch test record with time-to-disable; Rollback runbook	—	Critical gap
[ ]	UC-SEC-Q4	GL-05, IS-07	Test plan and results; Acceptance criteria; Release sign-off	—	Missing evidence
[ ]	UC-GEN-Q1	IS-14	Red-team / adversarial test results; Remediation records; Re-test evidence	—	Critical gap
[ ]	UC-GEN-Q2	IS-12	Versioned runtime policy; Policy decision logs; Enforcement-mode configuration	—	Missing evidence
[ ]	UC-GEN-Q3	IS-16	Limit configuration; Limit-breach alerts	—	User-asserted
[ ]	UC-GEN-Q4	EI-05, IS-10	Model registry entries with versions; Prompt/config version history	EV-SP-014	User-asserted
[ ]	UC-GEN-Q5	IS-07, IS-06	Accuracy metrics with thresholds; Safety evaluation results	—	Missing evidence
[ ]	UC-AGT-Q1	EI-07	Agent registry entry; Tool/permission manifest per agent	—	Missing evidence
[ ]	UC-AGT-Q2	IS-11	Tool permission matrix; Access-scope configuration; Access review records	—	Critical gap
[x]	UC-AGT-Q3	IS-13	Approval rules in runtime policy; Approval records with approver identity	EV-SP-020	Verified
[ ]	UC-AGT-Q4	SE-08	Log configuration; Tamper-evidence mechanism; Retention settings; Sample log extract	—	Missing evidence
[ ]	UC-AGT-Q5	IS-12, IS-16	Versioned runtime policy; Limit configuration; Limit-breach alerts	—	Missing evidence
[ ]	UC-FAIR-Q2	IS-06	Harm analysis; Safety evaluation results; Residual-risk sign-off	—	Missing evidence
[x]	UC-FAIR-Q3	IS-08	Disclosure text and placement; User-facing documentation	EV-SP-030	Verified
[ ]	UC-FAIR-Q4	IS-08, AO-11	Explanation approach; Feedback channel; Feedback log	—	Missing evidence
[ ]	UC-HUM-Q1	IS-09	Oversight design document; Override/appeal procedures; Oversight operation records	—	Missing evidence
[ ]	UC-HUM-Q2	AO-05	Training curriculum; Completion records by role	—	Missing evidence
[ ]	UC-HUM-Q3	AO-06, SE-04	Escalation matrix; AI incident procedure; Sample escalation records	—	User-asserted
[ ]	UC-HUM-Q4	GL-07	Go-live checklist; Condition verification record	—	Missing evidence
[ ]	UC-VEN-Q1	GL-11	Vendor AI questionnaire; Due-diligence approval	EV-SP-040	User-asserted
[ ]	UC-VEN-Q2	GL-11, AO-09	Contract AI clauses; Responsibility allocation (e.g. RACI or contract schedule)	—	Missing evidence
[ ]	UC-VEN-Q3	EI-08, AO-09	Vendor AI register; Vendor AI owner assignments	—	User-asserted
[ ]	UC-VEN-Q4	GL-04, EI-05	Change tickets referencing reassessment; Model registry entries with versions	—	Missing evidence

Done	Question	Controls	Evidence expected	Evidence provided	Status
[ ]	UC-MON-Q1	GL-08, SE-12	Monitoring dashboards; Alert thresholds; Monitoring review records	—	Missing evidence
[ ]	UC-MON-Q2	SE-04	AI incident procedure; Incident log; Post-incident reviews	—	Missing evidence
[ ]	UC-MON-Q3	SE-02, SE-05	Evidence repository; Retention policy; Sample evidence pack	—	Missing evidence
[ ]	UC-MON-Q4	GL-12, EI-11	Review calendar by tier; Recertification records	—	Missing evidence
[ ]	UC-MON-Q5	GL-06	Technical documentation pack; Model/system card	—	Missing evidence

Only items marked [x] have evidence reviewed by a named reviewer.

9. Runtime guardrail recommendations

- **RG-PII-REDACTION** — Redact personal and sensitive data in prompts, responses and logs (IS-04, IS-03)
- **RG-INJECTION-FILTER** — Detect and block prompt-injection and jailbreak attempts, including indirect injection in retrieved content (IS-14, IS-12)
- **RG-TOOL-ALLOWLIST** — Allow-list tools and scopes per agent; deny by default (IS-11, EI-07)
- **RG-HUMAN-APPROVAL** — Require human approval for high-impact actions (refunds, record changes, external messages, deletions) (IS-13, IS-09)
- **RG-LIMITS** — Enforce rate, token, spend and per-action value limits (IS-16, IS-12)
- **RG-ACTION-LOGGING** — Log every model and tool call with trace ID, redacted inputs and policy decision (SE-08)
- **RG-KILL-SWITCH** — Provide a kill switch to disable the system, agent or individual tools (IS-15)
- **RG-DISCLOSURE** — Display AI-interaction disclosure to end users (IS-08)

VERITRAIL Shield advisor rating: High (see the draft runtime policy for details; activation in production requires human approval).

Draft guardrail policies can be generated with VERITRAIL Shield; activating or changing a production runtime policy requires human approval (IS-12, GL-04).

10. Human approvals

Approval	Type	Status	Resource	Requested by	Resolved by
apr_mvklu9wj9f5d1afa	confirm_risk_tier	approved	sys_mvklu9wg75f1615d	u-asha	u-dana
apr_mvklua5fd8691937	change_risk_tier	pending	sys_mvklu9wg75f1615d	u-asha	—

Appendix A — Evidence status definitions

Status	Definition
Verified	Evidence exists and has been reviewed
User-asserted	User claims implementation, but evidence is absent
Inferred	Inferred as a likely gap or fact from responses or metadata
Missing evidence	Required evidence has not been provided
Critical gap	Material privacy, security, safety, legal, or operational exposure

Appendix B — Audit trace

Tool calls and agent turns for this assessment are recorded in the hash-chained VERITRAIL audit log (SE-08).

Timestamp (UTC)	Trace ID	Action	Actor	Outcome	Audit record
2026-10-23T06:44:30	trc_mvklu9zjb76d2f87	agent.tool.submit_assessment_response	u-asha	success	aud_mvklu9zk2d8a797d
2026-10-23T06:44:30	trc_mvklu9zjb76d2f87	agent.turn	u-asha	success	aud_mvklu9zo0e421ecb
2026-10-23T06:44:30	trc_mvklu9zr29b7ed27	agent.tool.submit_assessment_response	u-asha	success	aud_mvklu9zt723de11d
2026-10-23T06:44:30	trc_mvklu9zr29b7ed27	agent.turn	u-asha	success	aud_mvklu9zw8498d528
2026-10-23T06:44:30	trc_mvklu9zy4fcf56e7	agent.tool.submit_assessment_response	u-asha	success	aud_mvklu9zz04f7d288
2026-10-23T06:44:30	trc_mvklu9zy4fcf56e7	agent.turn	u-asha	success	aud_mvklua029e8e409b
2026-10-23T06:44:30	trc_mvklua03e0753d81	agent.tool.submit_assessment_response	u-asha	success	aud_mvklua052fa99f6b
2026-10-23T06:44:30	trc_mvklua03e0753d81	agent.turn	u-asha	success	aud_mvklua07edd9cd68
2026-10-23T06:44:30	trc_mvklua089e925dd3	agent.tool.submit_assessment_response	u-asha	success	aud_mvklua0a9b696c66
2026-10-23T06:44:30	trc_mvklua089e925dd3	agent.turn	u-asha	success	aud_mvklua0c2dcd6e52
2026-10-23T06:44:30	trc_mvklua0d32f3c29d	agent.tool.submit_assessment_response	u-asha	success	aud_mvklua0f9f32af14
2026-10-23T06:44:30	trc_mvklua0d32f3c29d	agent.turn	u-asha	success	aud_mvklua0i75d12675
2026-10-23T06:44:30	trc_mvklua0icc3f4854	agent.tool.submit_assessment_response	u-asha	success	aud_mvklua0k1a3b8a44
2026-10-23T06:44:30	trc_mvklua0icc3f4854	agent.turn	u-asha	success	aud_mvklua0n7a3f5c3f
2026-10-23T06:44:30	trc_mvklua0o69dcd09f	agent.tool.submit_assessment_response	u-asha	success	aud_mvklua0q5fd0f903
2026-10-23T06:44:30	trc_mvklua0o69dcd09f	agent.turn	u-asha	success	aud_mvklua0t95882d0a
2026-10-23T06:44:30	trc_mvklua0u14c96517	agent.tool.submit_assessment_response	u-asha	success	aud_mvklua0wfe56eda1
2026-10-23T06:44:30	trc_mvklua0u14c96517	agent.turn	u-asha	success	aud_mvklua0z41d33fc5
2026-10-23T06:44:30	trc_mvklua10082cf58c	agent.tool.submit_assessment_response	u-asha	success	aud_mvklua11e8f8bc57
2026-10-23T06:44:30	trc_mvklua10082cf58c	agent.turn	u-asha	success	aud_mvklua147bb6a974
2026-10-23T06:44:30	trc_mvklua150413056c	agent.tool.submit_assessment_response	u-asha	success	aud_mvklua177d3e7bd8
2026-10-23T06:44:30	trc_mvklua150413056c	agent.turn	u-asha	success	aud_mvklua1a385224ae
2026-10-23T06:44:30	trc_mvklua1a5d70a26c	agent.tool.submit_assessment_response	u-asha	success	aud_mvklua1c4d5ba942
2026-10-23T06:44:30	trc_mvklua1a5d70a26c	agent.turn	u-asha	success	aud_mvklua1icf717ff8
2026-10-23T06:44:30	trc_mvklua1j92e3d8fd	agent.tool.submit_assessment_response	u-asha	success	aud_mvklua1m7fe888f2
2026-10-23T06:44:30	trc_mvklua1j92e3d8fd	agent.turn	u-asha	success	aud_mvklua1qe088a1a8

Timestamp (UTC)	Trace ID	Action	Actor	Outcome	Audit record
2026-10-23T06:44:30	trc_mvklua1q9a05373e	agent.tool.submit_assessment_response	u-asha	success	aud_mvklua1sb79ac06e
2026-10-23T06:44:30	trc_mvklua1q9a05373e	agent.turn	u-asha	success	aud_mvklua1y124e8ead
2026-10-23T06:44:30	trc_mvklua1zfa7470b0	agent.tool.submit_assessment_response	u-asha	success	aud_mvklua219d20a7c7
2026-10-23T06:44:30	trc_mvklua1zfa7470b0	agent.turn	u-asha	success	aud_mvklua246235768c
2026-10-23T06:44:30	trc_mvklua2575624040	agent.tool.submit_assessment_response	u-asha	success	aud_mvklua27b1890a6d
2026-10-23T06:44:30	trc_mvklua2575624040	agent.turn	u-asha	success	aud_mvklua2a0d9b3929
2026-10-23T06:44:30	trc_mvklua2b7532b4a6	agent.tool.submit_assessment_response	u-asha	success	aud_mvklua2e039dcd49
2026-10-23T06:44:30	trc_mvklua2b7532b4a6	agent.turn	u-asha	success	aud_mvklua2h54e2dbb3
2026-10-23T06:44:30	trc_mvklua2i45da6ec9	agent.tool.submit_assessment_response	u-asha	success	aud_mvklua2kaccb0efd
2026-10-23T06:44:30	trc_mvklua2i45da6ec9	agent.turn	u-asha	success	aud_mvklua2n50059e53
2026-10-23T06:44:30	trc_mvklua2ofe66b709	agent.tool.submit_assessment_response	u-asha	success	aud_mvklua2q3ad630b1
2026-10-23T06:44:30	trc_mvklua2ofe66b709	agent.turn	u-asha	success	aud_mvklua2tb75d3717
2026-10-23T06:44:30	trc_mvklua2u9cf34242	agent.tool.submit_assessment_response	u-asha	success	aud_mvklua2w69d9bc1e
2026-10-23T06:44:30	trc_mvklua2u9cf34242	agent.turn	u-asha	success	aud_mvklua31617babe1
2026-10-23T06:44:30	trc_mvklua32440432b5	agent.tool.submit_assessment_response	u-asha	success	aud_mvklua34f22f42be
2026-10-23T06:44:30	trc_mvklua32440432b5	agent.tool.identify_gaps	u-asha	success	aud_mvklua3890dfdc37
2026-10-23T06:44:30	trc_mvklua32440432b5	agent.tool.recommend_controls	u-asha	success	aud_mvklua3cf26e26ec
2026-10-23T06:44:30	trc_mvklua32440432b5	agent.turn	u-asha	success	aud_mvklua3j28764816
2026-10-23T06:44:30	trc_mvklua3k9ae825a6	evidence.reviewed	u-dana	success	aud_mvklua3kae72e958
2026-10-23T06:44:30	trc_mvklua3m083a5be3	evidence.reviewed	u-dana	success	aud_mvklua3m91fcbcc8
2026-10-23T06:44:30	trc_mvklua3nce16b415	evidence.reviewed	u-dana	success	aud_mvklua3n6fdf9229
2026-10-23T06:44:30	trc_mvklu9wfba9d2937	approval.approved	u-dana	success	aud_mvklua3r29908af3
2026-10-23T06:44:30	trc_mvklua3rb6e3dd49	agent.tool.identify_gaps	u-asha	success	aud_mvklua3vdf39d2a9
2026-10-23T06:44:30	trc_mvklua3rb6e3dd49	agent.turn	u-asha	success	aud_mvklua45971bad07
2026-10-23T06:44:30	trc_mvklua45287ed6de	agent.tool.create_remediation_task	u-asha	success	aud_mvklua4a56f82964
2026-10-23T06:44:30	trc_mvklua45287ed6de	agent.turn	u-asha	success	aud_mvklua4ide0ae48a

Timestamp (UTC)	Trace ID	Action	Actor	Outcome	Audit record
2026-10-23T06:44:30	trc_mvklua4j0eb022ea	agent.tool.create_remediation_task	u-asha	success	aud_mvklua4p7b02a1c5
2026-10-23T06:44:30	trc_mvklua4j0eb022ea	agent.turn	u-asha	success	aud_mvklua4u0766f9e7
2026-10-23T06:44:30	trc_mvklua4v97e47fb9	agent.tool.draft_runtime_policy	u-asha	success	aud_mvklua57d0a10bda
2026-10-23T06:44:30	trc_mvklua4v97e47fb9	agent.turn	u-asha	success	aud_mvklua5cd10cfd9c
2026-10-23T06:44:30	trc_mvklua5d4bc7efda	agent.turn	u-asha	success	aud_mvklua5k5b40756a
2026-10-23T06:44:30	trc_mvklua5k2ad6c75b	agent.turn	u-asha	success	aud_mvklua5pbb0ac4ec
2026-10-23T06:44:31	trc_mvklua5q9ca6dd34	agent.tool.generate_report	u-asha	success	aud_mvkluaie0cf36853
2026-10-23T06:44:31	trc_mvklua5q9ca6dd34	agent.turn	u-asha	success	aud_mvkluaih0dba0bbc

Appendix C — Method and limitations

- Answers are self-reported; VERITRAIL has not inspected systems or documents unless evidence is marked Verified.
- The risk tier is preliminary and rule-based; the EU AI Act category screen is a trigger for legal review, not a legal classification.
- Framework mappings are indicative VERITRAIL interpretations from the Control Library, not official crosswalks.
- Regulatory applicability timelines must be verified against the current Official Journal text and any amendments.

Disclaimer

VERITRAIL supports governance readiness, control implementation and evidence collection. It does not certify ISO/IEC 42001 conformity, guarantee EU AI Act compliance, or replace legal advice. Framework mappings are indicative.

This use-case assessment produces an indicative view of governance readiness for a single AI system. Self-reported answers are User-asserted; only evidence reviewed by a named reviewer is Verified. Risk tiers are Inferred and require human confirmation. Framework mappings are indicative. VERITRAIL does not certify ISO/IEC 42001 conformity, guarantee EU AI Act compliance, or replace legal advice.

Synthetic example — fictional data.